

SamplePLC-7800 Series

Industrial Controller - Security & Hardening Manual

Document version 2.4 · April 2026 · Fictional test document for OTShield Research Studio smoke testing. Any resemblance to real vendor material is coincidental.

1. Product Overview

The SamplePLC-7800 is a modular programmable logic controller designed for process-industry deployments in the 200-2,000 I/O point range. It supports Modbus TCP, S7Comm, OPC UA, and EtherNet/IP concurrently on a single network interface. The device ships with four logical communication channels, each of which can be independently enabled, disabled, or rate-limited through the web-based engineering portal.

A factory-fresh controller boots with all four protocols enabled and no authentication. Operators are expected to complete the hardening checklist in Section 5 before exposing the device to any network segment reachable from IT.

1.1 Model Variants

Three variants ship under the 7800 family: the 7810 (entry tier, 8 digital inputs), the 7820 (mid tier, 32 mixed I/O, supports safety interlocks), and the 7850 (high tier, 128 mixed I/O, dual redundant power). All variants share the same firmware image, so the security guidance in this manual applies uniformly across the family.

2. Network Interfaces & Default Ports

Each protocol listens on a well-known TCP port as shown below. If your site policy mandates non-default ports, the mapping can be changed under Engineering Portal → Network → Service Ports. Note that changing the S7Comm port breaks compatibility with legacy STEP7 clients.

Protocol	Port	Default	Notes
Modbus TCP	502	Enabled	No authentication in spec; restrict by ACL
S7Comm	102	Enabled	ISO-TP over TCP; protected by S7 security v2
OPC UA	4840	Enabled	Basic256Sha256 profile; disable Anonymous
EtherNet/IP	44818	Enabled	Disable if not in use
Engineering Web	443	Enabled	TLS 1.2+; change default password
Diagnostic Shell	22	Disabled	SSH, for factory service only

The diagnostic shell on port 22 is disabled on factory-default firmware version 4.8.1 and later. If an attacker can open a TCP connection to port 22 of a production controller, the device has been downgraded or tampered with - treat as a P1 incident.

3. Modbus TCP Function Code Matrix

The SamplePLC-7800 implements the standard Modbus TCP function codes listed below. Any request carrying a function code outside this matrix is answered with exception code 01 (Illegal Function) and logged to the audit buffer. Rare or diagnostic function codes should not appear in normal production traffic; their presence is a strong indicator of reconnaissance or protocol fuzzing.

Code	Name	Expected in production?	OTShield anomaly class
0x01	Read Coils	Yes	Baseline
0x03	Read Holding Registers	Yes	Baseline
0x04	Read Input Registers	Yes	Baseline
0x05	Write Single Coil	Yes, infrequent	Suspicious if bursty
0x06	Write Single Register	Yes, infrequent	Suspicious if bursty
0x08	Diagnostics	No	Reconnaissance indicator
0x11	Report Slave ID	No	Reconnaissance indicator
0x17	Read/Write Multiple Registers	Rare	Suspicious
0x2B	Encapsulated Interface Transport	No	Reconnaissance indicator
0x5A	Vendor-specific (Safe-Stop)	No	Incident - immediate alert

Function code 0x5A, vendor-specific Safe-Stop, drops the controller into emergency-stop state. This code is intended for use by safety PLCs on a dedicated safety network only. Its appearance on the production network should trigger an immediate P1 incident and attacker engagement through the nearest decoy.

4. S7Comm Protocol Notes

S7Comm runs on TCP port 102 over ISO-on-TCP (RFC 1006). The SamplePLC-7800 implements S7 Security v2, which adds TLS-wrapped S7Comm on an alternate port 8102. Plaintext S7Comm on 102 remains enabled by default for compatibility with STEP7 versions prior to V16.

4.1 Common PDU Function Types

The PDU function byte in an S7Comm message identifies the action being requested. The four most common values seen in production are 0xF0 (Setup communication), 0x04 (Read variable), 0x05 (Write variable), and 0x1A (Request download). Function 0x1D (Start upload) and 0x1F (Upload) are used to extract PLC program blocks and should only be seen during scheduled engineering windows.

An unexpected 0x1D (Start upload) outside of an engineering window is a high-severity indicator: the attacker is attempting to exfiltrate the control logic. Pair this detection with a decoy controller in the same VLAN so OTShield can characterise the attacker's TTPs before they reach a real PLC.

4.2 Authentication Modes

Three authentication levels are available. Legacy mode accepts any client (not recommended outside of air-gapped commissioning). Password mode requires a 4-byte shared secret that is transmitted in the clear - treat this as obfuscation, not authentication. Certificate mode, introduced in firmware 4.7.0, binds every session to an X.509 client certificate issued by the site's internal CA.

5. Hardening Checklist

Work through this checklist after commissioning and again at every major firmware upgrade. OTShield's NIS2 dashboard tracks each item as a discrete compliance control; a fully hardened controller will show all green.

- Change the default **admin / siemens-7800** credentials on the engineering web portal (port 443). Use a password of at least 14 characters.
- Disable any protocol your site does not actually use. In practice most SCADA deployments only need Modbus TCP *or* S7Comm - rarely both.
- Set up an allow-list of engineering-workstation IPs in Engineering Portal → Network → Access Control. Block everything else at the switch.
- Enable audit logging and forward syslog to OTShield (UDP/514). Minimum facility: local6. The SamplePLC-7800 emits one audit line per Modbus write and per S7Comm session.
- Rotate the S7 Security v2 certificate every 365 days. The controller will raise a warning event starting 30 days before expiry.
- Pair each production controller with a decoy twin on the same VLAN. The decoy should mimic the real PLC's Modbus register map but expose one canary register that no legitimate client would ever touch.
- Confirm that firmware integrity is verified at boot (Secure Boot → Enforced). Any downgrade attempt to firmware below 4.5.0 should fail.

6. Incident Response Snippets

When an anomaly is raised against a SamplePLC-7800 the following evidence set is the minimum that should be collected before any remediation action.

- Full PCAP of the attacker's session (OTShield Dashboard → PCAP Analysis, filter by src IP).
- Audit buffer dump from the controller: GET /api/v1/audit?since=<epoch> on port 443.
- S7 Security v2 session log. Location: /var/log/s7sec/sessions.jsonl.
- Output of `diag netstat` taken within 60 seconds of the first anomaly.

6.1 Escalation Matrix

Indicator	Severity	Action
Function code 0x5A seen	CRITICAL	Isolate VLAN, page site SOC
S7Comm 0x1D outside window	HIGH	Open case, engage decoy
Repeated failed web auth ($\geq$ 10/min)	MEDIUM	Block source IP
Firmware downgrade attempt	CRITICAL	Physical inspection

7. Glossary

Modbus TCP — Request-response protocol running over TCP port 502, used to read and write coils, discrete inputs, holding registers, and input registers on industrial devices.

S7Comm — Proprietary Siemens protocol used by STEP7 to communicate with S7-300, S7-400, S7-1200, and S7-1500 PLCs. Runs over ISO-on-TCP on port 102.

Decoy twin — A fake PLC deployed on the same VLAN as a real controller, mimicking its register map so that attacker traffic can be observed without risking the real device.

Canary register — A holding register with no legitimate purpose. Any read or write against a canary is, by definition, malicious.

ISO-on-TCP — RFC 1006. Transports the ISO 8073 connection-oriented transport protocol over a plain TCP connection. Widely used by S7Comm and other legacy industrial protocols.

End of document - [SamplePLC-7800 Security Manual v2.4](#). For the latest version check the (fictional) [vendor portal](#).